

Vulnerability Management in the Enterprise

The Three Legs: People / Process / Technology

Technology is the smallest part of VM. Two-thirds is process and politics:

Scanners, Agents & the Two Perspectives

Network scanner (Nessus/Qualys/Rapid7) – external view, what ACTUALLY responds

Agent-based (CrowdStrike, Defender, or vendor agents) – internal truth, apps, missing patches, even offline assets

Both – because network shows exposure, agent shows install-state

```
# qualys/nc tool equivalent example:
# run a config/agent audit for missing patches:
#   systemctl get-default    (systemd meeting runtime state on a Linux box)
#   dpkg --get-selections | wc -l    (*Julia* package census on Debian-like)
```

Patching Windows (The Patch Tuesday Rhythm)

Microsoft ships cumulative updates the **second Tuesday of each month**

End of Support = the silent killer (EOL OS = zero patches = permanent criticals)

Testing ring: pilot → broad → critical

Maintenance windows are BUSINESS decisions, not IT preferences

The Approval Wars (Process Honestly)

The 'why is this still open?' question has predictable answers:

No approved downtime

Vendor says "don't patch"
Application breaks with patch (incompatibility)
Nobody owns the asset
End-of-life (can't patch – the fix is decommission or network-isolate)

The manager's skill: each is a *decision*, not a stall. An 'accepted risk' finding needs a named owner + sign-off date + scheduled re-review.

SLAs & The Judgment of 'Due Today'

Classic VM SLAs:

Severity (after triage)	Patch by
Critical (exploited/exposed)	7 days
High	30 days
Medium	90 days
Low	next maintenance

Exceptions flag themselves up the chain: "critical, internet-facing, KEV, can't patch within 7" is an EXECUTIVE decision, not a silent budget cut.

Reporting to the Business

Executives care about: risk in, risk out, exposure trend, and the Top 10 hotspots.

Report monthly: patched vs exposed by risk class
Trend: did MTTD/MTTR shift?
Hotspots: names, not numbers ("Domain Controllers, RDP, unpatched since Apr")

The reality of enterprise VM: you don't fight the scanner; you fight ownership, windows, standards and the twilight zone of 'nobody noticed we had a legacy server'. Master that and the CVEs mostly take care of themselves.

← Prioritization: CVSS, EPSS &...

Module complete ✓